Respostas: atividade sobre autenticação e autorização com JWT

Aluno: Arthur Fogaça Martins

1) Qual a diferença entre autenticação e autorização? Dê um exemplo.

Autenticação é saber quem o usuário é, normalmente pelo login com e-mail e senha. Autorização é saber o que esse usuário pode fazer depois de logado, de acordo com o papel dele.

Exemplo: um usuário CLIENTE faz login e recebe o token (autenticação). Se ele tentar cadastrar um imóvel, o sistema nega, porque só ADMIN pode fazer isso (autorização). Sem token o erro é 401; com token mas sem permissão o erro é 403.

2) Qual a diferença entre stateful e stateless?

No stateful o servidor guarda o estado do usuário, como na sessão: depois do login ele lembra quem você é através de um cookie. No stateless o servidor não guarda nada, e cada requisição precisa mandar o token para dizer quem é o usuário. O JWT é stateless, por isso é mais fácil de escalar, mas o token só deixa de valer quando expira.

3) Qual a semântica e sintaxe de um JWT?

Semântica: o JWT é um token assinado pelo servidor que guarda informações sobre o usuário, como o e-mail, o papel e a data de expiração. Como é assinado, se alguém mudar o conteúdo o servidor percebe. Ele não é criptografado, então não se coloca senha dentro.

Sintaxe: são três partes em Base64 separadas por ponto, `header.payload.signature`. O header diz o algoritmo (ex.: HS256), o payload tem os dados (sub, role, exp) e a signature é a assinatura feita com a chave secreta do servidor. O token é enviado no cabeçalho `Authorization: Bearer <token>`.

4) Implementação

Foi feita no projeto da imobiliária com Spring Security. O login devolve um token e as rotas ficaram assim:

Ação	Rota	Quem acessa
Login	POST /public/login	Todos
Listar imóveis / um imóvel	GET /imoveis, GET /imoveis/{id}	Todos
Cadastrar, alterar e remover imóveis	POST, PUT, DELETE /imoveis	ADMIN
Cadastrar e gerenciar usuários	/api/usuarios	ADMIN
Alterar status de imóvel	PATCH /imoveis/{id}/status	Qualquer usuário logado

Sem token ou com token inválido/expirado a API retorna 401. Com token de CLIENTE em rota de ADMIN retorna 403.